



Authorizing Data Access On-Behalf-Of Users

Steps to OBO Access



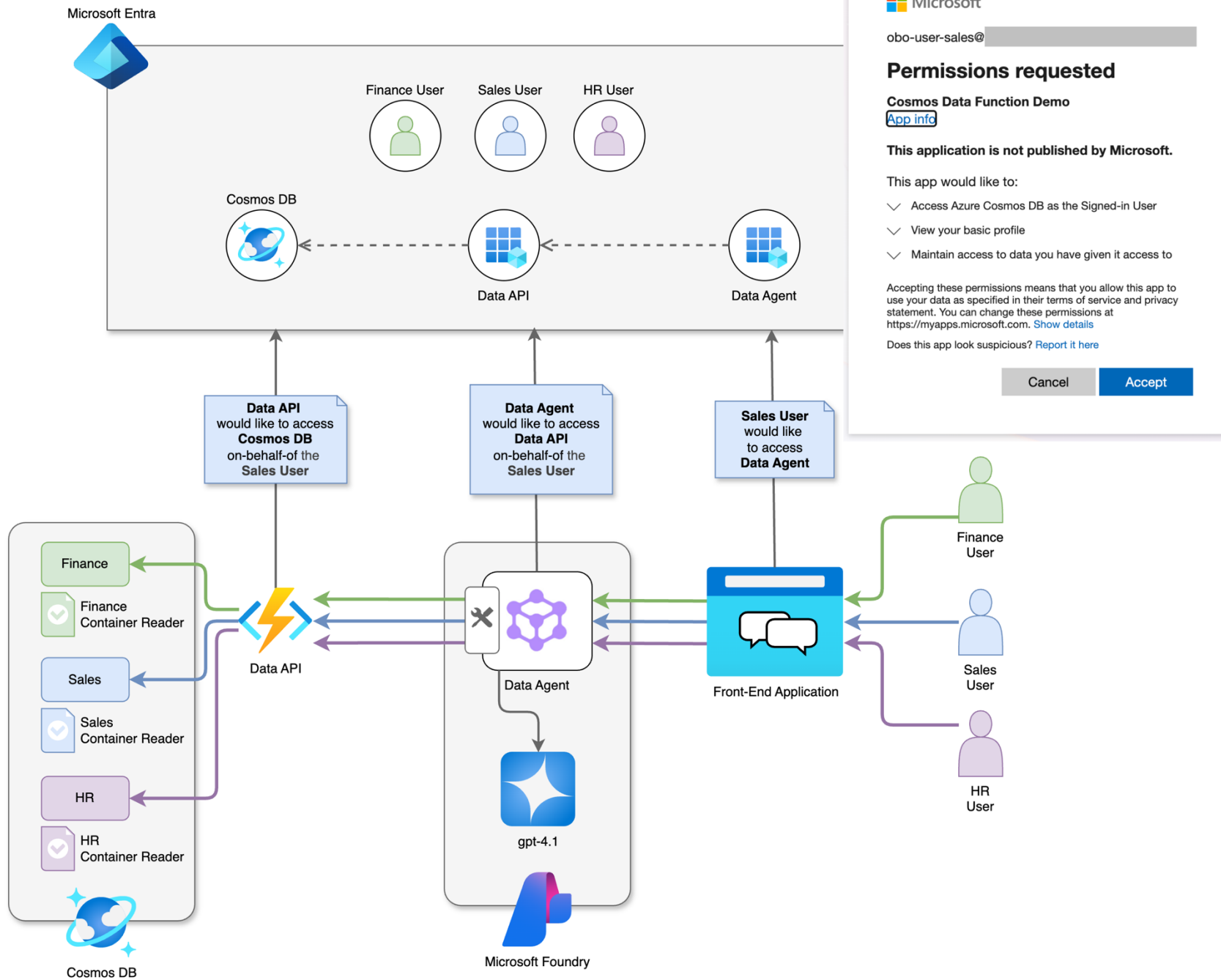
Authorize the user at
the data layer



Orchestrate access
tokens through the
service layers



Authenticate the user
at the application
layer





← End User with identity and data level authorization



← Front-end UI with chat interface



← Microsoft Agent Framework application to interact with data via OpenAPI tool calls



← Azure Functions expose an API to read container data



← Cosmos DB with data stored in containers

**Authorize the user at
the data layer**





User Accessing Sales Container

OBO User Sales is authorized to access data inside the **Sales Container**.

The screenshot displays the Azure Cosmos DB web interface. The top navigation bar shows the Microsoft Azure logo, the Cosmos DB service, and the specific database instance 'obo-cosmos-auwz6k237u2d6'. The user is logged in as 'OBO User Sales' with the email 'obo-user-sales@MngEnvMCAP698108.onmicrosoft.com'. The left sidebar shows a tree view of the database structure, with 'DemoDatabase' expanded and 'Sales' selected. The 'Sales' container is highlighted in green. The main area shows a table of items with columns 'id' and 'region'. The item with 'id' 3 and 'region' 'North' is selected. The right pane shows the JSON document for this item, which includes fields like 'id', 'region', 'product', 'quantity', 'revenue', 'quarter', '_rid', '_self', '_etag', '_attachments', and '_ts'.

id	region
1	West
2	East
3	North
4	South
5	West

```
1 {
2   "id": "3",
3   "region": "North",
4   "product": "Widget C",
5   "quantity": 175,
6   "revenue": 19250,
7   "quarter": "Q1",
8   "_rid": "SVgIAK7j0voDAAAAAAAAA==",
9   "_self": "dbs/SVgIAA==/colls/SVgIAK7j
10  "_etag": "\"a701f4c0-0000-0700-0000-6
11  "_attachments": "attachments/",
12  "_ts": 1771257928
13 }
```



User Accessing Sales Container

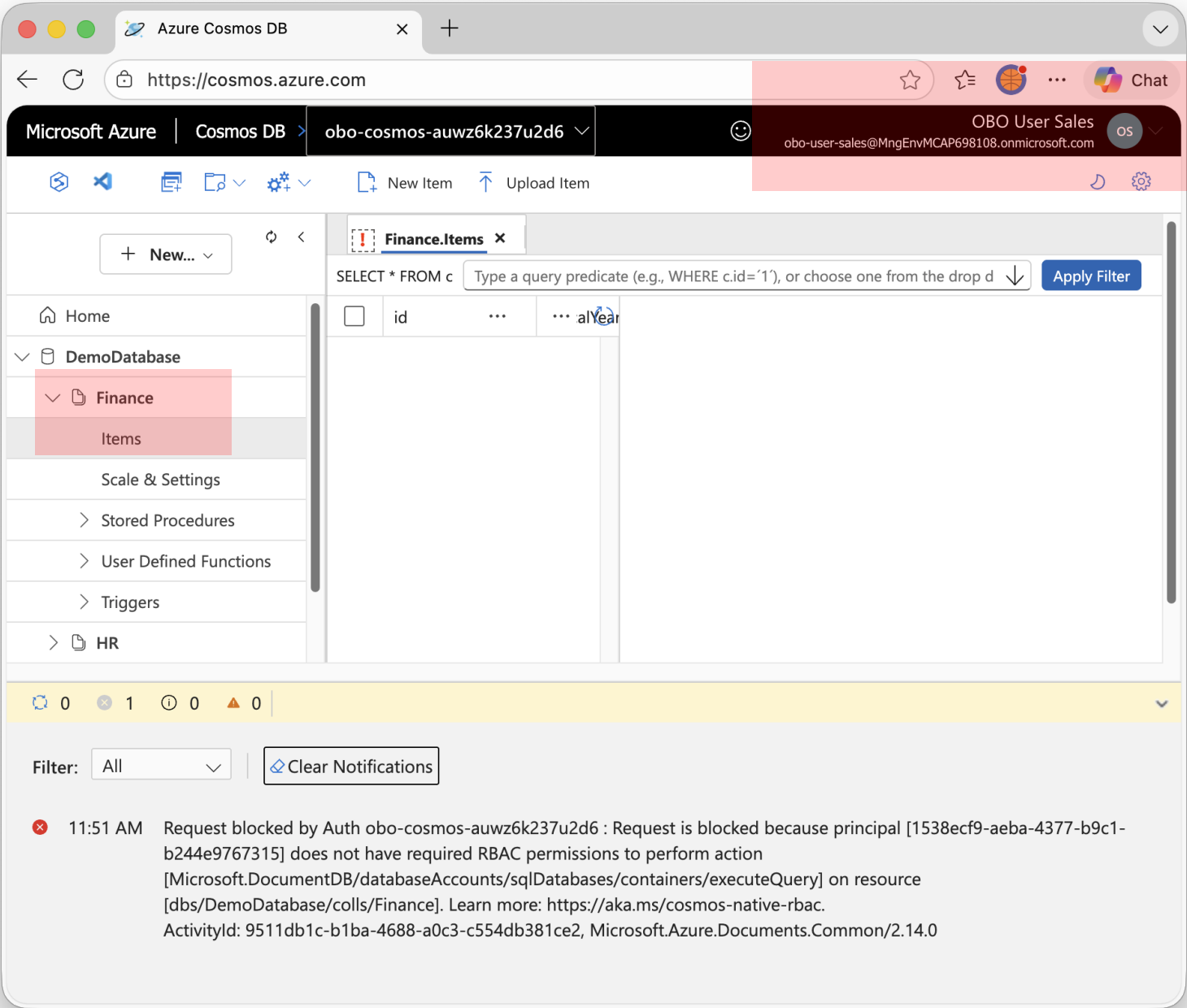
OBO User Sales is authorized to access data inside the **Sales Container**.

```
1  {
2      // Cosmos SQL Role Definition
3      "id": ".../2ff3ab2c-3858-5512-bbfe-1e646597a60e",
4      "roleName": "Sales Container Reader",
5      "assignableScopes": [
6          ".../databaseAccounts/obo-cosmos-auwz6k237u2d6/dbs/DemoDatabase/colls/Sales"
7      ],
8      "permissions": [
9          {
10             "dataActions": [
11                 "Microsoft.DocumentDB/databaseAccounts/readMetadata",
12                 "Microsoft.DocumentDB/databaseAccounts/sqlDatabases/containers/items/read",
13                 "Microsoft.DocumentDB/databaseAccounts/sqlDatabases/containers/executeQuery"
14             ]
15         }
16     ]
17 }
18
19
20
21 {
22     // Cosmos SQL Role Assignment
23     "id": ".../15ce30e5-f315-45a7-aa8c-b3aec2c79138",
24     "type": "Microsoft.DocumentDB/databaseAccounts/sqlRoleAssignments",
25
26     // OBO User Sales
27     "principalId": "1538ecf9-aeba-4377-b9c1-b244e9767315",
28
29     // Role Definition
30     "roleDefinitionId": ".../2ff3ab2c-3858-5512-bbfe-1e646597a60e",
31
32     // Scope
33     "scope": ".../databaseAccounts/obo-cosmos-auwz6k237u2d6/dbs/DemoDatabase/colls/Sales"
34 }
```



User Blocked From Finance Container

OBO User Sales is NOT authorized to access data inside the **Finance Container**.





User Accessing HR Container

OBO User HR is authorized to access data inside the **HR Container**.

The screenshot shows the Azure Cosmos DB web interface. The browser address bar displays `https://cosmos.azure.com`. The top navigation bar includes "Microsoft Azure", "Cosmos DB", and the account identifier "obo-cosmos-auwz6k237u2d6". The user is logged in as "OBO User HR" with email "obo-user-hr@MngEnvMCP698108.onmicrosoft.com".

The left sidebar shows a tree view of the database structure: "DemoDatabase" (expanded) contains "Finance", "HR" (expanded), "Items" (selected), "Scale & Settings", "Stored Procedures", "User Defined Functions", "Triggers", and "Sales".

The main area displays the "HR.Items" container. A table lists items with columns "id", "...", and "... partm". Item 4 is selected, showing a JSON document in the right pane:

```
1 {
2   "id": "4",
3   "department": "Sales",
4   "employeeName": "Person D",
5   "position": "Sales Representative",
6   "startDate": "2021-09-20",
7   "status": "Active",
8   "_rid": "SVgIAL8DApsEAAAAAAAAA==",
9   "_self": "dbs/SVgIAA==/colls/SVgIAL8D",
10  "_etag": "\"17005c88-0000-0700-0000-6",
11  "_attachments": "attachments/",
12  "_ts": 1771257928
13 }
```

The bottom status bar shows 1 error, 1 warning, 0 info, and 0 debug messages.



User Blocked From Sales Container

OBO User HR is NOT authorized to access data inside the **Sales Container**.

Microsoft Azure | Cosmos DB > obo-cosmos-auwz6k237u2d6

OBO User HR
obo-user-hr@MngEnvMCAP698108.onmicrosoft.com

+ New...

Home

▼ DemoDatabase

> Finance

> HR

▼ Sales

Items

Scale & Settings

> Stored Procedures

> User Defined Functions

Sales.Items

SELECT * FROM c

Type a query predicate (e.g., WHERE c.id='1'), or choose one from the drop d

Apply Filter

id /region

1 2 0 0

Querying triggers for container Sales

Filter: All

Clear Notifications

12:20 PM

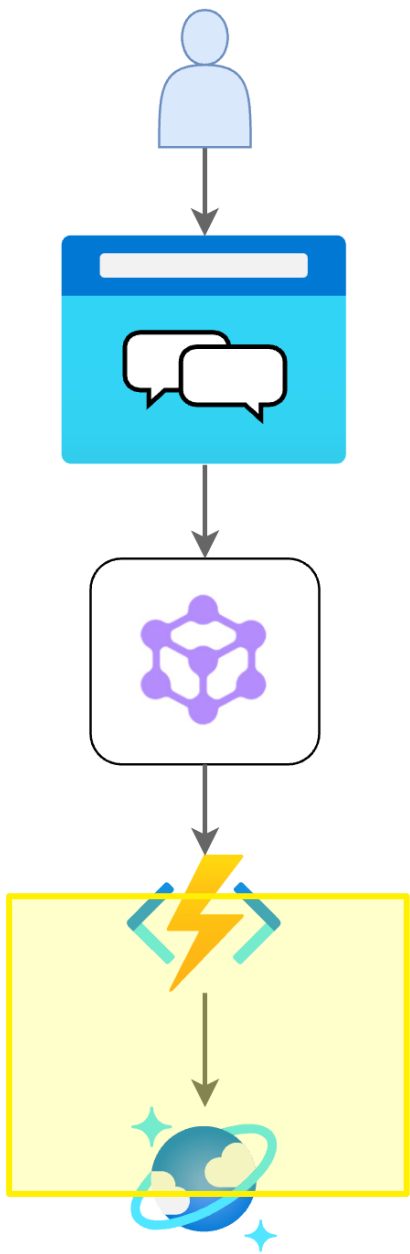
Request blocked by Auth obo-cosmos-auwz6k237u2d6 : Request is blocked because principal [525ea289-2e77-4e60-8310-19cfdb39bd63] does not have required RBAC permissions to perform action [Microsoft.DocumentDB/databaseAccounts/sqlDatabases/containers/executeQuery] on resource [dbs/DemoDatabase/colls/Sales]. Learn more: https://aka.ms/cosmos-native-rbac. ActivityId: 131dd8d7-3b9a-4374-a675-7aefe2bc267e, Microsoft.Azure.Documents.Common/2.14.0

12:13 PM

Request blocked by Auth obo-cosmos-auwz6k237u2d6 : Request is blocked because principal [525ea289-2e77-4e60-8310-19cfdb39bd63] does not have required RBAC permissions to perform action

**Orchestrate access
tokens through the
service layers**





Microsoft Azure portal interface showing the "Cosmos Data Function Demo | API permissions" page. The page displays a list of configured permissions for the application, including "user_impersonation" with delegated access to Azure Cosmos DB.

Microsoft Azure portal interface showing the "Cosmos Data Function Demo | API permissions" page. The page displays a list of configured permissions for the application, including "user_impersonation" with delegated access to Azure Cosmos DB.

Search resources, services, and docs (G+)

Home > App registrations > Cosmos Data Function Demo

Cosmos Data Function Demo | API permissions

Search

Refresh | Got feedback?

Overview

Quickstart

Integration assistant

Diagnose and solve problems

Manage

- Branding & properties
- Authentication (Preview)
- Certificates & secrets
- Token configuration
- API permissions**
- Expose an API
- App roles
- Owners
- Roles and administrators
- Manifest

Support + Troubleshooting

- New support request

Granting tenant-wide consent may revoke permissions that have already been granted tenant-wide for that application. Permissions that users have already granted on their own behalf aren't affected. [Learn more](#)

The "Admin consent required" column shows the default value for an organization. However, user consent can be customized per permission, user, or app. This column may not reflect the value in your organization, or in organizations where this app will be used. [Learn more](#)

Configured permissions

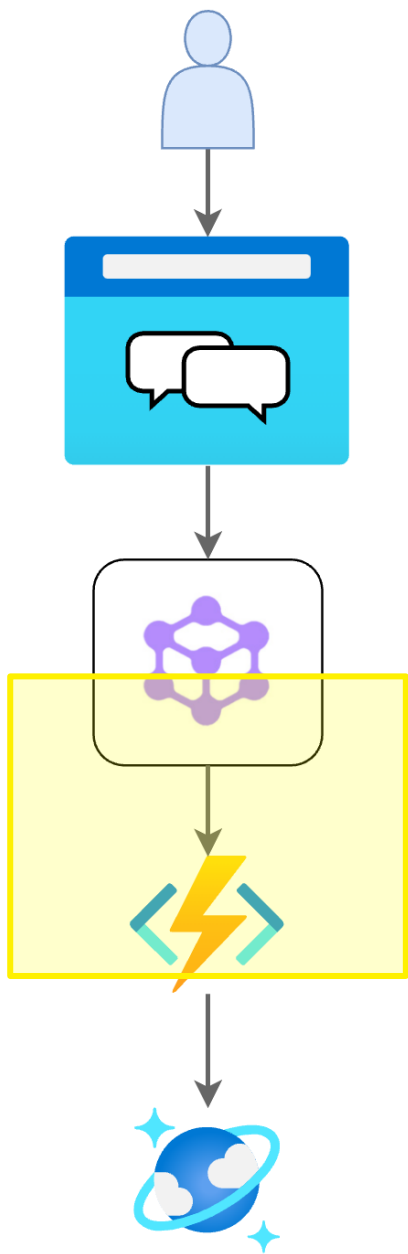
Applications are authorized to call APIs when they are granted permissions by users/admins as part of the consent process. The list of configured permissions should include all the permissions the application needs. [Learn more about permissions and consent](#)

+ Add a permission ✓ Grant admin consent for Contoso

API / Permissions name	Type	Description	Admin consent required
Azure Cosmos DB (1)			
user_impersonation	Delegated	Access Azure Cosmos DB	No

To view and manage consented permissions for individual apps, as well as your tenant's consent settings, try [Enterprise applications](#).

Add or remove favorites by pressing Cmd+Shift+F



https://portal.azure.com/#view/Microsoft_AAD_RegisteredApps/ApplicationMenuBlade/~/. ...

Microsoft Azure Search resources, services, and docs (G+)

Home > App registrations > Cosmos Data Function Demo

Cosmos Data Function Demo | Expose an API

Search

Got feedback?

Application ID URI : `api://6bc00924-e342-4714-b94e-33a9544c1d92` Edit

Scopes defined by this API

Define custom scopes to restrict access to data and functionality protected by the API. An application that requires access to parts of this API can request that a user or admin consent to one or more of these.

Adding a scope here creates only delegated permissions. If you are looking to create application-only scopes, use 'App roles' and define app roles assignable to application type. [Go to App roles](#).

+ Add a scope

Scopes	Who can consent	Admin consent display na...	User consent display na...
<code>api://6bc00924-e342-4714-b94e-33a9544c1d92/user_impersonation</code>	Admins only	user_impersonation	

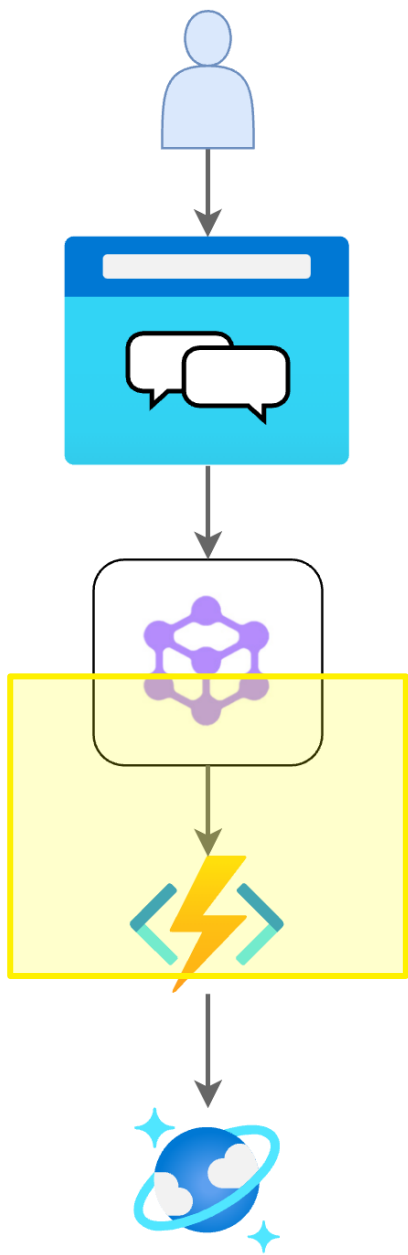
Authorized client applications

Authorizing a client application indicates that this API trusts the application and users should not be asked to consent when the client calls this API.

+ Add a client application

Client Id	Scopes
<code>95c8825e-d2d0-43c0-ae5b-787c47fc2df2</code>	1

Add or remove favorites by pressing `Cmd+Shift+F`



Microsoft Azure portal interface showing the 'Foundry Agent Demo | API permissions' page. The page displays a list of configured permissions for the application, including 'user_impersonation' with a status of 'Granted for Contoso'.

URL: [https://portal.azure.com/#view/Microsoft_AAD_RegisteredApps/ApplicationMenuBlade/~/...](https://portal.azure.com/#view/Microsoft_AAD_RegisteredApps/ApplicationMenuBlade/~/)

Search resources, services, and docs (G+)

Home > App registrations > Foundry Agent Demo

Foundry Agent Demo | API permissions

Search Refresh Got feedback?

Overview Quickstart Integration assistant Diagnose and solve problems Manage Branding & properties Authentication (Preview) Certificates & secrets Token configuration API permissions Expose an API App roles Owners Roles and administrators Manifest Support + Troubleshooting New support request

Granting tenant-wide consent may revoke permissions that have already been granted tenant-wide for that application. Permissions that users have already granted on their own behalf aren't affected. [Learn more](#)

The "Admin consent required" column shows the default value for an organization. However, user consent can be customized per permission, user, or app. This column may not reflect the value in your organization, or in organizations where this app will be used. [Learn more](#)

Configured permissions

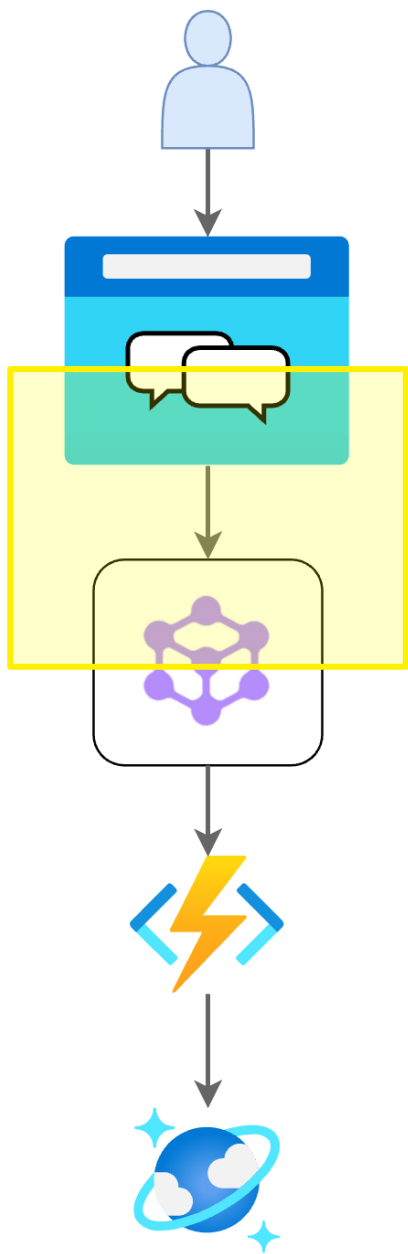
Applications are authorized to call APIs when they are granted permissions by users/admins as part of the consent process. The list of configured permissions should include all the permissions the application needs. [Learn more about permissions and consent](#)

+ Add a permission Grant admin consent for Contoso

API / Permissions name	Type	Description	Admin consent req...	Status
Cosmos Data Function Demo (1)				
user_impersonation	Delegated	user_impersonation	Yes	Granted for Contoso

To view and manage consented permissions for individual apps, as well as your tenant's consent settings, try [Enterprise applications](#).

Add or remove favorites by pressing Cmd+Shift+F



Microsoft Azure portal interface showing the configuration for the Foundry Agent Demo API.

Foundry Agent Demo | Expose an API

Application ID URI : `api://95c8825e-d2d0-43c0-ae5b-787c47fc2df2` [Edit](#)

Scopes defined by this API

Define custom scopes to restrict access to data and functionality protected by the API. An application that requires access to parts of this API can request that a user or admin consent to one or more of these.

Adding a scope here creates only delegated permissions. If you are looking to create application-only scopes, use 'App roles' and define app roles assignable to application type. [Go to App roles](#).

[+ Add a scope](#)

Scopes	Who can consent	Admin consent display ...	User consent display na...
<code>api://95c8825e-d2d0-43c0-ae5b-787c47fc2df2/user_impersonation</code>	Admins and users	user_impersonation	

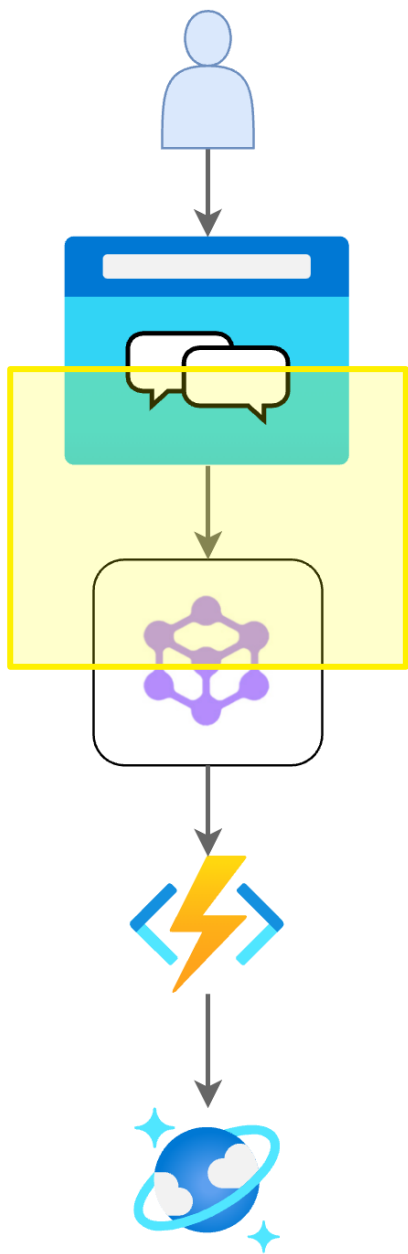
Authorized client applications

Authorizing a client application indicates that this API trusts the application and users should not be asked to consent when the client calls this API.

[+ Add a client application](#)

Client Id	Scopes
No client applications have been authorized	

Add or remove favorites by pressing `Cmd+Shift+F`



Microsoft Azure portal interface showing the "Catay Bruno | API permissions" page. The page displays a list of configured permissions for the application "Foundry Agent Demo (1)".

Microsoft Azure Search resources, services, and docs (G+)

Home > App registrations > Catay Bruno

Catay Bruno | API permissions

Search Refresh Got feedback?

Overview

- Quickstart
- Integration assistant
- Diagnose and solve problems
- Manage
 - Branding & properties
 - Authentication (Preview)
 - Certificates & secrets
 - Token configuration
 - API permissions**
 - Expose an API
 - App roles
 - Owners
 - Roles and administrators
 - Manifest
- Support + Troubleshooting
 - New support request

Configured permissions

Applications are authorized to call APIs when they are granted permissions by users/admins as part of the consent process. The list of configured permissions should include all the permissions the application needs. [Learn more about permissions and consent](#)

[Add a permission](#) [Grant admin consent for Contoso](#)

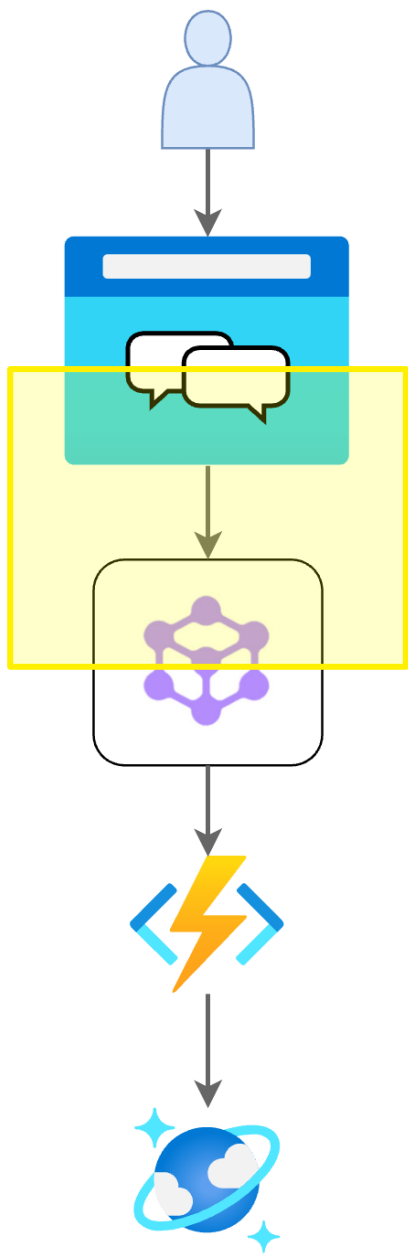
API / Permissions name	Type	Description	Admin consent req...	Status
Foundry Agent Demo (1)				
user_impersonation	Delegated	user_impersonation	No	...

To view and manage consented permissions for individual apps, as well as your tenant's consent settings, try [Enterprise applications](#).

https://learn.microsoft.com/entra/identity/enterprise-apps/grant-admin-consent?WT.mc_id=Portal-Microsoft_AAD_RegisteredApps

**Authenticate the user
at the application
layer**





My Workspace

Collections

- OBO Function App
 - agent
 - POST Chat Response
 - POST fastapi test
 - api
 - POST Seed Data
 - GET Get User Access
 - POST Query Finance Data
 - POST Query Sales Data
 - POST Query HR Data
 - cosmos consent

OBO Function App

agent POST Query HR Data POST Chat Response

Headers Script Test Vars Auth * Docs

Configuration

Callback URL

☒ Use system browser for OAuth

Authorization URL

Access Token URL

Client ID

Client Secret

Scope

State

Add Credentials to Basic Auth Header

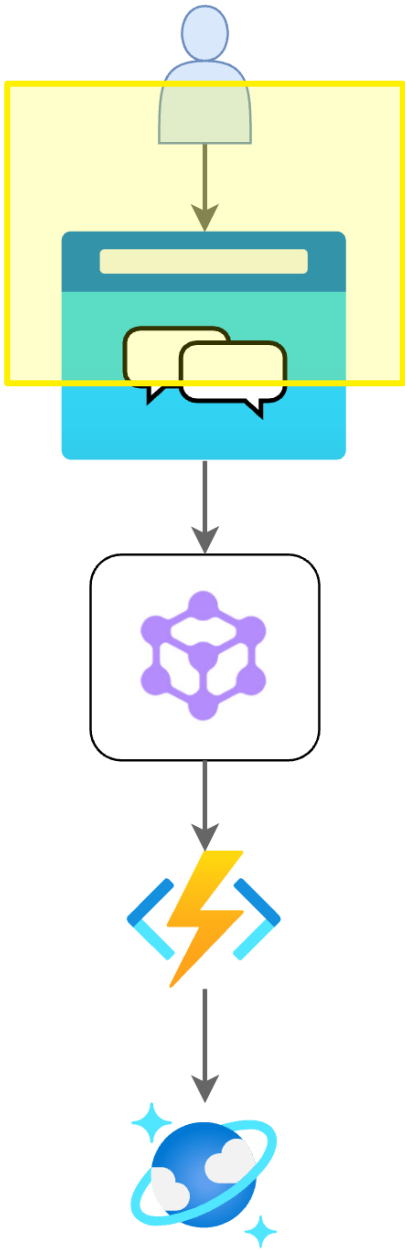
Use PKCE ☒

Token

Token ID

Add token to Headers

Header Prefix Bearer



obo-user-sales@

Permissions requested

Cosmos Data Function Demo

[App info](#)

This application is not published by Microsoft.

This app would like to:

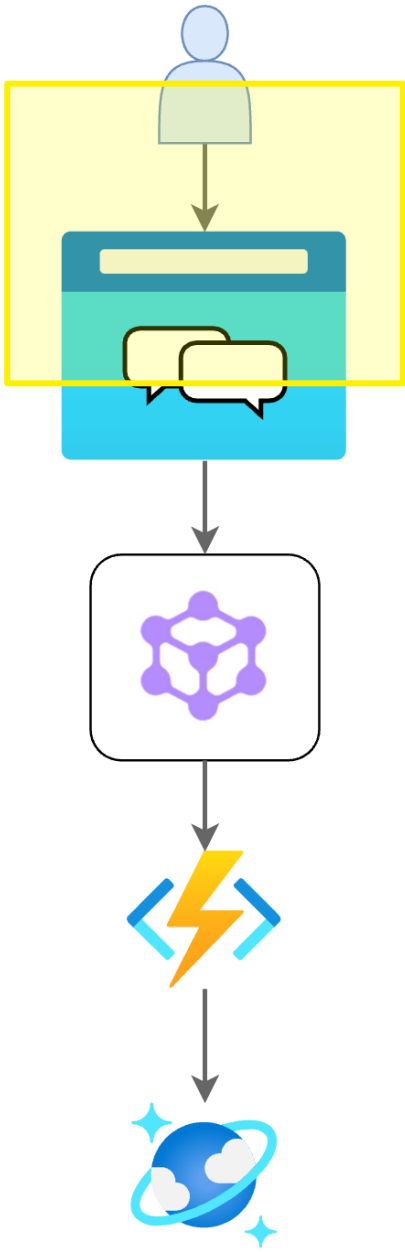
- ✓ Access Azure Cosmos DB as the Signed-in User
- ✓ View your basic profile
- ✓ Maintain access to data you have given it access to

Accepting these permissions means that you allow this app to use your data as specified in their terms of service and privacy statement. You can change these permissions at <https://myapps.microsoft.com>. [Show details](#)

Does this app look suspicious? [Report it here](#)

Cancel

Accept



My Workspace

Brno

Collections

- OBO Function App
 - agent
 - POST Chat Response
 - POST fastapi test
 - api
 - POST Seed Data
 - GET Get User Access
 - POST Query Finance ...
 - POST Query Sales Data
 - POST Query HR Data
 - cosmos consent

OBO Function App

agent POST Query HR Data POST Chat Response

POST {{agentHost}}/responses

Body * >> JSON Prettify

```
1 {
2   "input": "show me sales data",
3   "stream": false
4 }
```

Response Headers 5 Timeline Tests

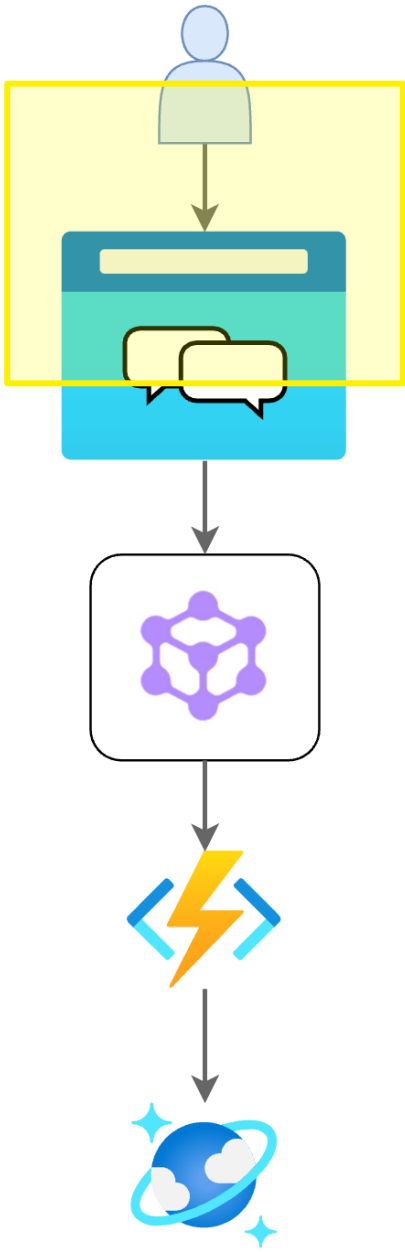
JSON 200 OK 19.55s 1022B

```
1 {
2   "metadata": {"+1"},
3   "temperature": 0.0,
4   "top_p": 0.0,
5   "user": "me",
6   "id": "id",
7   "created_at": 1771422117,
8   "output": [
9     {
10      "status": "completed",
11      "content": [
12        {
13          "text": "Here is the latest sales data:\n\n1. Region: West | Product: Widget A | Quantity: 150 | Revenue: $15,000 | Quarter: Q1\n2. Region: East | Product: Widget B | Quantity: 200 | Revenue: $24,000 | Quarter: Q1\n3. Region: North | Product: Widget C | Quantity: 175 | Revenue: $19,250 | Quarter: Q1\n4. Region: South | Product: Widget A | Quantity: 225 | Revenue: $22,500 | Quarter: Q2\n5. Region: West | Product: Widget B | Quantity: 300 | Revenue: $36,000 | Quarter: Q2\n\nLet me know if you need more details or a specific breakdown!",
14          "annotations": [],
15          "type": "output_text"
16        }
17      ],
18      "type": "message",
19      "role": "assistant"
20    }
21  ],
22  "object": "response"
23 }
```

API Specs

Try Bruno Ultimate

Search Cookies Dev Tools v3.1.1



My Workspace

OBO Function App

- agent
 - POST Chat Response
 - POST fastapi test
- api
 - POST Seed Data
 - GET Get User Access
 - POST Query Finance Data
 - POST Query Sales Data
 - POST Query HR Data
- cosmos consent
- foundry-agent-identities
- foundry-auth

OBO Function App

agent POST Chat Response POST Query Finance Data api

POST {{agentHost}}/responses

Body >> JSON Prettify

```
1 {
2   "input": "show me finance data",
3   "stream": false
4 }
```

Response >> {} JSON 200 OK 8.39s 1.1KB

```
8   "id": "id",
9   "created_at": 1772024023,
10  "output": [
11    {
12      "status": "completed",
13      "content": [
14        {
15          "text": "I attempted to access the Finance data for you. However, the system returned an error: Unauthorized: Invalid or missing authentication token.\n\nCosmos function response (for debugging):\n\n  \"success\": false,\n  \"error\": \"Unauthorized: Invalid or missing authentication token\"\n\n\nIt appears you do not have valid authentication or access rights to the Finance data, or your session may have expired. If you believe you should have access, please ensure you are properly logged in, or contact your administrator for assistance.",
16          "annotations": [],
17          "type": "output_text"
18        }
19      ],
20      "type": "message"
```

API Specs +

Try Bruno Ultimate

Search Cookies Dev Tools v3.1.3